



AERO-GUARD

Compliance in Motion, Profit in Motive



Prototype Progress Report

MVP build — Sections 1 through 7 complete

Date: 30 June 2026

Prepared by: Curtis L.Y. Kasukusa

Prototype URL: `aeroguard_flask/` — runs on Python 3.11 + Flask

7

sections complete

58

engineering tasks shipped

6

technical docs written



AERO-GUARD

Compliance in Motion, Profit in Motive

Executive summary

AERO-GUARD is a compliance and revenue-protection tool for travel agencies. It plugs into a GDS (Galileo, Amadeus, Sabre) terminal to catch fare-rule violations *before* they trigger airline ADMs (Agency Debit Memos), automates passport-to-PNR data entry, and gives the provider company a helpdesk console for agencies, vouchers, escalations and audits.

The brief was to evolve the visual prototype into a functional MVP that the client can pitch to travel agencies and airlines. This report covers the first seven sections of that build. The result is a real multi-tenant SaaS with authentication, role-based permissions, isolated tenants, an audit trail, and a live event stream that makes the dashboard feel like a production system.

- Three provider companies (AERO-GUARD HQ, SkyOps Africa, Horizon GDS Partners) and one travel-agency consultant can log in with their own credentials.
- Each provider only ever sees their own agencies, vouchers, escalations and helpdesk staff — strict cross-tenant isolation.
- Three role tiers (ADMIN, L2, L1) gate destructive actions; junior staff are prevented from provisioning, deleting or invoking high-value vouchers.
- Every state change is recorded in an append-only audit log — visible to admins with filters by action, actor and date.
- A simulated GDS event stream injects ADM catches, voucher issuances and alert refreshes every 45–90 seconds — the dashboard moves on its own.
- One click resets all demo data to a clean baseline before each pitch.
- Demo data persists across server restarts; SQLite locally, Postgres-ready for production.

What is deliberately simulated

The prototype does **not** connect to a real GDS. GDS access requires signed reseller agreements with Travelport / Amadeus / Sabre, KYC, insurance and a multi-month onboarding. For pitches, the simulated event stream demonstrates the workflow convincingly without the regulatory burden. The architecture is designed so a real GDS adapter can drop into the same event-handling code.

What we built, section by section

The build plan has thirteen sections. Sections 1–7 are complete. Sections 8–12 wrap deployment, the public landing page and production hardening — work that does not change the product, just how customers reach it.

§	Section	Status
1	Project hygiene — requirements, env vars, Procfile, secrets	Done
2	Database — SQLAlchemy, migrations, seed, persistence	Done
3	Authentication — login, sessions, CSRF, rate limiting	Done
4	Roles & permissions — ADMIN / L2 / L1 matrix	Done
5	Multi-tenancy — strict per-provider data isolation	Done
6	Workflow polish — real timestamps, audit log UI, reset	Done
7	Live event stream — background scheduler, dashboard widget	Done
8	Reports — CSV exports across ADM savings + SLA stats	Planned
9	Deployment — Render hosting, custom domain, HTTPS	Planned
10	Public landing page, About, Privacy, Terms	Planned
11	Backups, error tracking (Sentry), uptime monitoring	Planned
12	Hardening — CSP, HSTS, Redis-backed scheduler	Planned
13	Demo-readiness pass — script, Loom video, pitch deck	Planned

AG

AERO-GUARD

Compliance in Motion, Profit in Motive

1

Project hygiene

DONE

The kitchen, ready for guests

- **requirements.txt** with pinned versions — anyone can clone the repo and run it without hunting for the right Flask version.
- **Procfile** tells Render / Railway exactly how to start the server in production (gunicorn, two workers).
- **.env.example** documents which secret settings the app expects (SECRET_KEY, FLASK_ENV, PORT) — the real .env is gitignored.
- Secrets read from environment variables. The app **refuses to start in production without a SECRET_KEY** — eliminates the "forgot to change the default password" class of bug.
- Debug mode automatically off in production.

2

Database & persistence

DONE

Data that survives restarts

- **13 tables** defined in models.py — providers, users, agencies, vouchers, escalations, threads, messages, audit logs, plus shared catalogs.
- **SQLAlchemy + Alembic migrations** — when the schema changes, an automatic recipe file updates every environment (laptop, staging, production) to match.
- **SQLite locally, Postgres-ready** — switching is one environment variable, no code change.
- **Soft delete** on agencies — removing them preserves history so audit logs never reference dead pointers.
- **flask seed** and **flask reset-demo** commands — one-second recovery to a clean demo state.
- Every operational row carries a **provider_id** foreign key, ready for the tenant isolation that arrives in Section 5.

3

Authentication

DONE

A real front door

- Login page at **/login**, branded, lists demo accounts for easy self-exploration during a pitch.
- **Passwords are hashed** with PBKDF2-SHA-256 — never stored as plaintext, never recoverable.
- Session cookies: **HttpOnly** (JS can't steal them), **SameSite=Lax** (other sites can't ride along), **Secure in production** (HTTPS-only).
- **CSRF protection** on every form — defeats the "evil site tricks your browser" attack.
- **Rate limiting** on /login (5 attempts/minute per IP) — brute-forcing the password becomes impractical.
- **Forgot password** flow with a 2-hour token; renders the link on screen in demo (email sending arrives in production).

The logo consists of a blue rounded square containing the white letters 'AG' in a bold, sans-serif font.

AERO-GUARD

Compliance in Motion, Profit in Motive

- Five demo accounts ready: Provider Admin, Provider L2, Provider L1, an inactive user (to demo the disable flow), and a Consultant.
-

Roles & permissions

DONE

~~Defence in depth — UI, server, and tenancy each check~~

- Four roles defined: **ADMIN**, **L2**, **L1**, **CONSULTANT** — with a single permission matrix as the source of truth.
- **19 actions** mapped to roles (agency:provision, voucher:issue, escalation:to_vendor, ...) — easy to audit who can do what at a glance.
- **L1 voucher cap of \$500** — junior staff can issue small goodwill vouchers; anything bigger requires L2 or Admin.
- Buttons users can't use **are hidden**; locked actions show a dim "■" chip so it's clear the feature exists.
- Even if a user crafts the request by hand, the **server re-checks** and returns 403 — defence in depth.
- Consultants cannot reach /provider/* at all — separate audience, separate door.

Multi-tenancy

DONE

Provider A never sees Provider B's data

- Every list query is **tenant-scoped** automatically — Soviet's queries silently include "WHERE provider = AERO-GUARD HQ".
- Every single-record lookup checks ownership — a cross-tenant ID returns **404**, **not 403**, so attackers can't probe other tenants' ID space.
- Bulk actions silently ignore IDs that aren't yours — no partial damage if a malicious ID is appended to the form.
- CSV exports only contain own data.
- **Audit log writes** on every state change — who did what, when, against what record, in which tenant.
- **TENANT chip** in the topbar shows the current tenancy context — eliminates "wait, which account am I in?" mistakes during demos.
- Self-protection: admins cannot disable or remove their own account.

Workflow polish

DONE

Real timestamps + a visible audit trail + one-click reset

- Every "3 min ago" / "today" in the UI is now **computed from real datetimes** — not seeded strings that rot after a day.
- Login bumps **users.last_login_at**; mutations bump **updated_at**; SLA deadlines stored as real datetimes so "48 min left" is accurate.
- **Audit Log page** at /provider/audit-log (Admin only) — filter by action, by actor, by time window. Append-only.
- **Reset demo data** button on the dashboard — wipes every tenant, reseeds the baseline, signs out, sub-second.
- Dashboard hero personalised: "Welcome to AERO-GUARD, Soviet · ADMIN · MFA verified · last login just now".
- "ADMs Prevented" counter now computed from real agency data instead of a hardcoded number.

Live event stream

DONE

The dashboard breathes

- Background scheduler (APScheduler) injects **simulated GDS events every 45–90 seconds**: ADM catches, voucher issuances, alert refreshes.
- **Live Activity** card on the dashboard polls every 10 seconds and prepends new events with a fade-in animation.
- Pulsing green **LIVE** chip tells viewers this is not a screenshot.
- **Inject demo event** button (Admin only) — fire one event on cue for a specific pitch moment.
- Tenant-scoped — every provider sees a live feed of **their own** tenant's activity.
- Tunable cadence via env vars; full kill switch via AEROGUARD_STREAM=0.

What's next

The remaining sections do not change the product. They make it accessible at a public URL, observable in production, and presentable to a buyer.

§	Section	Why it matters for the pitch
8	Reports & CSV exports	Hand prospects a downloadable summary they can email to their CFO.
9	Deploy to Render + custom domain	Give the client a permanent https://aeroguard.io link they can share.
10	Marketing landing page	A non-logged-in visitor sees a product story, not a login form.
11	Backups, Sentry, uptime monitor	When something breaks, we know about it before the prospect does.
12	Hardening — CSP, HSTS, scheduled	Production-grade security headers and horizontal-scale readiness.
13	Pitch package	5-slide deck, one-page brief, Loom walkthrough, list of 20 target agencies.

Try it yourself

All demo accounts use the password **aeroguard**:

Role	Email	Lands on
Provider Admin	soviet@aero-guard.io	Provider console (full access)
Provider L2	tariro@aero-guard.io	Provider console (no provisioning)
Provider L1	kelvin@skyops.africa	Provider console (read + light actions)
Inactive user	amina@horizon.partners	Login refused — disabled account demo
Consultant	patrick@skylink.zw	Smartpoint terminal (cannot access /provider/*)

Recommended demo path

- Sign in as **soviet@aero-guard.io** — land on the provider dashboard, point out the LIVE Activity card and the TENANT chip.
- Wait 30–60 seconds — a new ADM-caught event appears in the Live Activity card without anyone touching the screen.
- Click **Inject demo event** for a guaranteed event on cue.
- Visit **Intelligence** → **Audit Log** to show append-only history (with the event you just injected).
- Sign out, sign in as **kelvin@skyops.africa** — point out the "Provision Agency" lock and the missing Suspend/Delete buttons.
- Try to visit **/provider/agencies/AG-1001/delete** as Kelvin — 403 Access Denied.

The logo consists of the letters 'AG' in white, bold, sans-serif font, centered within a blue rounded square.

AERO-GUARD

Compliance in Motion, Profit in Motive

- Sign out, sign in as **patrick@skylink.zw** — lands on the Smartpoint terminal, cannot reach /provider/* at all.

-
- Back as soviet — click ■ **Reset demo data** — everything snaps back to a clean baseline for the next prospect.